LAB REPORT

Role-Based Access Control (RBAC) and Least Privilege

CYS-262L — Information Security Lab

Session 4 | Linux Users, Groups, Permissions and Sudo

Student Name	_Muhammad Anees Ahmad__
Registration No.	_2025(S)-CYS-63_____

1. Objective

The objective of this lab was to understand Role-Based Access Control (RBAC) in Linux. I created role groups, assigned users to the correct groups, set permissions on department files, tested access, and configured limited sudo access for the IT security group.

2. Lab Environment

- Operating System: Kali Linux
- Working directory for source files: /home/kali/week3-lab
- Department directory: /srv/dept
- Main tools: useradd, usermod, groupadd, chmod, chown, test, visudo, systemctl and journalctl

3. Users and Role Groups

I used Linux groups to manage access according to each user's job role. This makes permission management easier than setting separate permissions for every user.

Role group	Purpose / user assignment
faculty	Ali — faculty documents
registrar	Sara — registrar documents
hr	Hina — HR/payroll file
itsec	Omar — IT security files and limited sudo
comms	Noor was moved out; Farah was added for Communications
No role group	Zain — used for access-denial and leaver tests

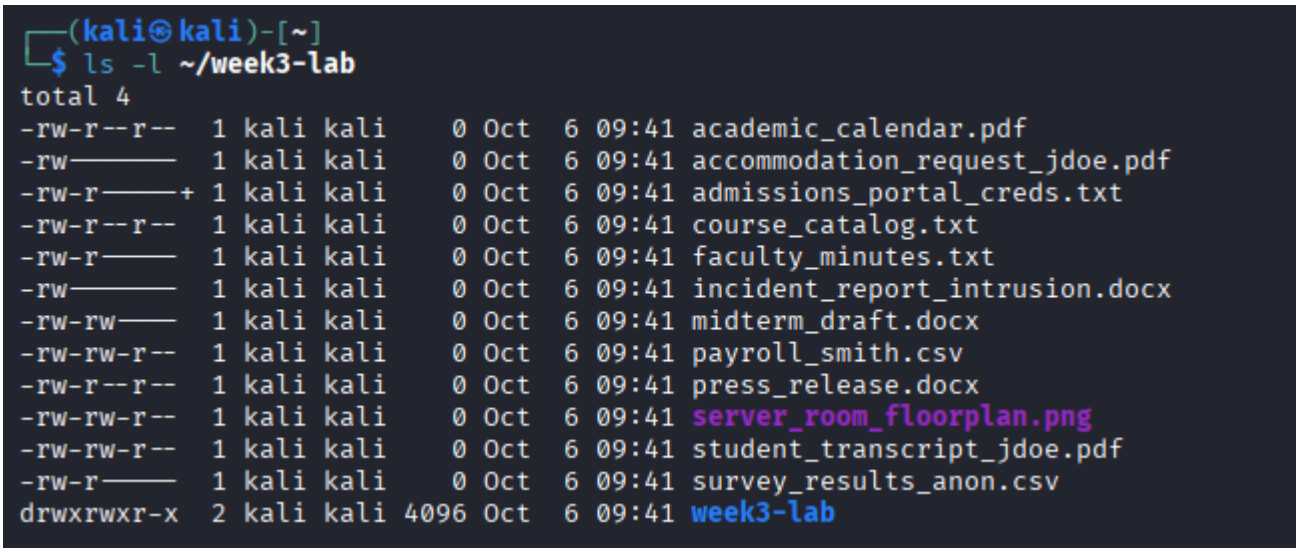


Figure 1. Terminal output showing the Week 3 source files in ~/week3-lab.

```
┌──(kali㉿kali)-[~]
└─$ id ali
id sara
id hina
id omar
id noor
id zain
uid=1001(ali) gid=1006(ali) groups=1006(ali),1001(faculty)
uid=1002(sara) gid=1007(sara) groups=1007(sara),1002(registrar)
uid=1003(hina) gid=1008(hina) groups=1008(hina),1003(hr)
uid=1004(omar) gid=1009(omar) groups=1009(omar),1004(itsec)
uid=1005(noor) gid=1010(noor) groups=1010(noor),1005(comms)
uid=1006(zain) gid=1011(zain) groups=1011(zain)
```

Figure 2. Terminal output showing user IDs and role group membership.

4. Department Directories and File Permissions

I organised the department files under /srv/dept. Each department folder was assigned to its role group. The setgid bit was used on department folders so that new files can inherit the folder's group. I checked the owner, group and permission mode with the find command.

Directory	Group	Example content
/srv/dept/faculty	faculty	Faculty minutes, midterm draft, survey results
/srv/dept/registrar	registrar	Transcript and accommodation request
/srv/dept/hr	hr	Payroll file
/srv/dept/itsec	itsec	Floor plan, credentials, incident report
/srv/dept/comms	comms	Course catalogue, press release, academic calendar

```
┌──(kali㉿kali)-[~]
└─$ sudo find /srv/dept -printf '%M %u:%g %p\n'
[sudo] password for kali:
drwx--x--x root:root /srv/dept
drwxrws--- root:itsec /srv/dept/itsec
-rw-r----- omar:itsec /srv/dept/itsec/server_room_floorplan.png
-rw-rw---- omar:itsec /srv/dept/itsec/incident_report_intrusion.docx
-rw-r----- omar:itsec /srv/dept/itsec/admissions_portal_creds.txt
drwxrws--- root:faculty /srv/dept/faculty
-rw-rw---- ali:faculty /srv/dept/faculty/faculty_minutes.txt
-rw-rw---- ali:faculty /srv/dept/faculty/midterm_draft.docx
-rw-rw---- ali:faculty /srv/dept/faculty/survey_results_anon.csv
drwxrws--- root:hr /srv/dept/hr
-rw-r----- hina:hr /srv/dept/hr/payroll_smith.csv
drwxrwsr-x root:comms /srv/dept/comms
-rw-rw-r-- farah:comms /srv/dept/comms/press_release.docx
-rw-r--r-- noor:comms /srv/dept/comms/academic_calendar.pdf
-rw-r--r-- noor:comms /srv/dept/comms/course_catalog.txt
drwxrws--- root:registrar /srv/dept/registrar
-rw-r----- sara:registrar /srv/dept/registrar/student_transcript_jdoe.pdf
-rw-r----- sara:registrar /srv/dept/registrar/accommodation_request_jdoe.pdf
```

Figure 3. Output of find showing directory ownership, group ownership and file modes under /srv/dept.

5. Access Control Testing

I used the Linux test command with sudo -u to check whether different users could read or write selected files. The results below are based on the terminal tests completed during the lab.

Test	Expected / observed result	Meaning
Ali writes faculty midterm draft	ALLOWED	Faculty user can edit the faculty file.
Ali reads HR payroll	DENIED	Faculty user cannot read HR payroll.
Hina reads HR payroll	ALLOWED	HR user can access the payroll file.
Hina reads faculty midterm draft	DENIED	HR user cannot read faculty material.
Sara reads student transcript	ALLOWED	Registrar user can access the transcript.
Omar reads student transcript	DENIED	IT security user cannot access registrar material.
Zain reads course catalogue	ALLOWED	Public catalogue is readable.
Zain writes course catalogue	DENIED	Public read access does not allow editing.
Zain reads IT security credentials	DENIED	Sensitive credentials are protected.
Noor writes press release after role move	DENIED	Noor no longer has Communications write access.
Farah writes press release	ALLOWED	Current Communications user can edit the file.

```
┌──(kali㉿kali)-[~]
└─$ sudo -u ali test -w /srv/dept/faculty/midterm_draft.docx && echo ALLOWED || echo DENIED
ALLOWED

┌──(kali㉿kali)-[~]
└─$ sudo -u ali test -r /srv/dept/hr/payroll_smith.csv && echo ALLOWED || echo DENIED
DENIED

┌──(kali㉿kali)-[~]
└─$ sudo -u hina test -r /srv/dept/hr/payroll_smith.csv && echo ALLOWED || echo DENIED
ALLOWED

┌──(kali㉿kali)-[~]
└─$ sudo -u hina test -r /srv/dept/faculty/midterm_draft.docx && echo ALLOWED || echo DENIED
DENIED

┌──(kali㉿kali)-[~]
└─$ sudo -u sara test -r /srv/dept/registrar/student_transcript_jdoe.pdf && echo ALLOWED || echo DENIED
ALLOWED

┌──(kali㉿kali)-[~]
└─$ sudo -u omar test -r /srv/dept/registrar/student_transcript_jdoe.pdf && echo ALLOWED || echo DENIED
DENIED

┌──(kali㉿kali)-[~]
└─$ sudo -u noor test -w /srv/dept/comms/press_release.docx && echo AL
AL

┌──(kali㉿kali)-[~]
└─$ sudo -u noor test -w /srv/dept/comms/press_release.docx && echo AL
AL

┌──(kali㉿kali)-[~]
└─$ sudo -u noor test -w /srv/dept/comms/press_release.docx && echo ALLOWED || echo DENIED
ALLOWED

┌──(kali㉿kali)-[~]
└─$ sudo -u zain test -r /srv/dept/comms/course_catalog.txt && echo ALLOWED || echo DENIED
ALLOWED

┌──(kali㉿kali)-[~]
└─$ sudo -u zain test -w /srv/dept/comms/course_catalog.txt && echo ALLOWED || echo DENIED
DENIED

┌──(kali㉿kali)-[~]
└─$ sudo -u zain test -r /srv/dept/itsec/admissions_portal_creds.txt && echo ALLOWED || echo DENIED
DENIED

┌──(kali㉿kali)-[~]
└─$ sudo chmod 644 /srv/dept/comms/course_catalog.txt

┌──(kali㉿kali)-[~]
└─$ sudo -u zain test -r /srv/dept/comms/course_catalog.txt && echo ALLOWED || echo DENIED
sudo -u zain test -w /srv/dept/comms/course_catalog.txt && echo ALLOWED || echo DENIED
ALLOWED
DENIED
```

```
┌──(kali㉿kali)-[~]
└─$ sudo -u noor test -w /srv/dept/comms/press_release.docx && echo ALLOWED || echo DENIED
DENIED

┌──(kali㉿kali)-[~]
└─$ sudo -u farah test -w /srv/dept/comms/press_release.docx && echo ALLOWED || echo DENIED
ALLOWED
```

Figure 4. Terminal output showing successful ALLOWED and DENIED access tests.

6. Restricted Sudo Access for IT Security

I created a sudoers rule for the itsec group using visudo. The rule allows the group to check the SSH service status and read SSH service logs. It does not give unrestricted root access.

```
%itsec ALL=(root) /usr/bin/systemctl --no-pager status ssh, /usr/bin/journalctl --no-pager -u ssh
```

I checked the syntax with visudo -c. Omar could run the allowed status command. The attempts to stop SSH and read /etc/shadow were rejected, which confirms that the rule was restricted.

```
┌──(kali㉿kali)-[~]
└─$ sudo -l -U omar
Matching Defaults entries for omar on kali:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User omar may run the following commands on kali:
    (root) /usr/bin/systemctl --no-pager status ssh, /usr/bin/journalctl --no-pager -u ssh

┌──(kali㉿kali)-[~]
└─$ sudo -iu omar
┌──(omar㉿kali)-[~]
└─$ sudo -l
\[sudo] password for omar:
Sorry, try again.
[sudo] password for omar:
Sorry, try again.
[sudo] password for omar:
Matching Defaults entries for omar on kali:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User omar may run the following commands on kali:
    (root) /usr/bin/systemctl --no-pager status ssh, /usr/bin/journalctl --no-pager -u ssh

┌──(omar㉿kali)-[~]
└─$ sudo -l
Matching Defaults entries for omar on kali:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User omar may run the following commands on kali:
    (root) /usr/bin/systemctl --no-pager status ssh, /usr/bin/journalctl --no-pager -u ssh

┌──(omar㉿kali)-[~]
└─$ sudo /usr/bin/systemctl --no-pager status ssh
○ ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: disabled)
     Active: inactive (dead)
       Docs: man:sshd(8)
             man:sshd_config(5)
```

Figure 5. Sudoers validation and Omar's allowed SSH status command.

```
┌──(omar㉿kali)-[~]
└─$ sudo /usr/bin/systemctl stop ssh
Sorry, user omar is not allowed to execute '/usr/bin/systemctl stop ssh' as root on kali.

┌──(omar㉿kali)-[~]
└─$ sudo cat /etc/shadow
Sorry, user omar is not allowed to execute '/usr/bin/cat /etc/shadow' as root on kali.
```

Figure 6. Terminal output showing that stopping SSH and reading /etc/shadow are not allowed.

7. Joiner, Mover and Leaver Lifecycle

Lifecycle event	Action performed	Result
Joiner	Created Farah and added her to comms.	Farah was able to write the press release.
Mover	Added Noor to faculty and removed her from comms.	Noor's write test on the press release returned DENIED.

Leaver	Zain's account is to be locked and expired.	Add final evidence after running usermod -L and chage -E 0.

```
┌──(kali㉿kali)-[~]
└─$ sudo useradd -m -s /bin/bash farah

┌──(kali㉿kali)-[~]
└─$ sudo passwd farah
New password:
Retype new password:
passwd: password updated successfully

┌──(kali㉿kali)-[~]
└─$ sudo usermod -aG comms farah

┌──(kali㉿kali)-[~]
└─$ sudo usermod -aG faculty noor
sudo gpasswd -d noor comms
Removing user noor from group comms

┌──(kali㉿kali)-[~]
└─$ sudo chown farah:comms /srv/dept/comms/press_release.docx

┌──(kali㉿kali)-[~]
└─$ id noor
ls -l /srv/dept/comms/press_release.docx
uid=1005(noor) gid=1010(noor) groups=1010(noor),1001(faculty)
-rw-rw-r-- 1 farah comms 0 Oct  9 10:24 /srv/dept/comms/press_release.docx

┌──(kali㉿kali)-[~]
└─$ sudo -u noor test -w /srv/dept/comms/press_release.docx && echo ALLOWED || echo DENIED
DENIED

┌──(kali㉿kali)-[~]
└─$ sudo -u farah test -w /srv/dept/comms/press_release.docx && echo ALLOWED || echo DENIED
ALLOWED
```

Figure 7. Evidence for Farah and Noor account/group changes and access tests.

```
┌──(kali㉿kali)-[~]
└─$ sudo usermod -L zain
sudo chage -E 0 zain

┌──(kali㉿kali)-[~]
└─$ sudo passwd -S zain
sudo chage -l zain
zain L 2026-10-09 0 99999 7 -1
Last password change                                    : Oct 09, 2026
Password expires                                        : never
Password inactive                                       : never
Account expires                                         : Jan 01, 1970
Minimum number of days between password change          : 0
Maximum number of days between password change          : 99999
Number of days of warning before password expires       : 7
```

Figure 8. Evidence for Zain's locked and expired account (complete after running the commands).

8. Reflection (150–200 words)

In this lab, I learned how Role-Based Access Control (RBAC) can improve security by assigning permissions through Linux groups. I created groups for faculty, registrar, HR, IT security and communications, then assigned users to their

job roles. I organised department files under /srv/dept and set file ownership and permissions. The setgid bit helps new files inherit the department group, which is useful for shared work. I tested read and write access with different users. These tests showed that users could access the files needed for their work, while access to other department files was denied. I also created a restricted sudoers rule for the IT security group. Omar could check the SSH service status, but he could not stop the service or read /etc/shadow. I practised the joiner and mover process by adding Farah to Communications and moving Noor to Faculty. I also learned that a leaver account should be locked and expired instead of being deleted immediately. Overall, the lab showed me that least privilege, regular access testing and careful account management are important for protecting confidential data.

Before submission: run the Zain lock/expiry commands, capture the final screenshot, and paste the screenshots into the marked spaces. Check the permissions against the instructor's Week 2/Week 3 requirements before submitting.